Compliance Annotation DataForge Analytics Ltd. Framework: GDPR + SOC 2 | Compliance Level: Highly Compliant

---

Finding 1: [COMPLIANT] GDPR: Data Controller and DPO Identification (Art. 13(1)(a-b)) The policy explicitly identifies DataForge Analytics Ltd. as the controller with a registered London address. It provides an ICO registration number (ZA123456) and names Emily Sanders as the dedicated Data Protection Officer (DPO), providing both an email and telephone contact. **References:** GDPR Art. 13(1)(a), Art. 37

Finding 2: [COMPLIANT] GDPR: Precision in Legal Bases & Balancing Tests (Art. 6(1)) Each processing purpose is mapped to a specific legal basis: Contract for service delivery , Legal Obligation for compliance , and Consent for marketing. For product improvement under Legitimate Interests, the policy specifies a balancing test was performed and processing is restricted to aggregated, pseudonymized data. **References:** GDPR Art. 6(1), Art. 13(1)(c)

Finding 3: [COMPLIANT] GDPR: Data Subject Rights and Modalities (Art. 12-22) All eight GDPR rights are listed, including the right to withdraw consent and the right to lodge a complaint with the ICO. The policy establishes a 30-day response window and provides a dedicated privacy portal for exercising these rights. **References:** GDPR Art. 15-22

Finding 4: [COMPLIANT] GDPR: Granular Retention & Tiered Transfers (Art. 13(2)(a), 44-46) Retention is defined by category: 12 months post-subscription for accounts, 24 months for usage, and 7 years for tax records. International transfers rely on 2021 Standard Contractual Clauses (Module 2) supplemented by a mandatory Transfer Impact Assessment (TIA) and the EU-U.S. Data Privacy Framework. **References:** GDPR Art. 13(2)(a), Art. 44-46

Finding 5: [COMPLIANT] SOC 2: Governance and Security Oversight (CC1) Security is led by a CISO reporting to the CTO with a direct escalation path to the Board. A cross-functional Security Steering Committee meets quarterly. Accountability is enforced through annual Code of Conduct acknowledgments and performance-linked security responsibilities. **References:** SOC 2 CC1.1, CC1.2, CC1.5

Finding 6: [COMPLIANT] SOC 2: Risk Assessment and Fraud Evaluation (CC3, CC9) The organization conducts annual and event-driven risk assessments, explicitly evaluating fraud risk factors. Risks are tracked via a GRC platform (Vanta) and require CISO/CTO sign-off for acceptance. **References:** SOC 2 CC3.1, CC3.2

Finding 7: [COMPLIANT] SOC 2: Logical Access and Zero-Trust Principles (CC6) MFA is mandatory for all users. Access is managed via RBAC (Okta) with quarterly reviews. Privileged "root" access is strictly time-bound, logged, and utilizes just-in-time (JIT) provisioning. **References:** SOC 2 CC6.1, CC6.2, CC6.3

Finding 8: [COMPLIANT] SOC 2: Data Encryption and Key Management (CC6, C1) At-rest data uses AES-256 encryption via AWS KMS with tenant-specific, customer-managed keys

(CMKs) rotated annually. In-transit data requires TLS 1.3 or 1.2, while database connections utilize mutual TLS. **References:** SOC 2 CC6.1, CC6.7, C1.1

Finding 9: [COMPLIANT] SOC 2: System Operations and Change Management (CC8) Changes are tracked in Jira, peer-reviewed in GitHub, and tested in mirrored staging environments. Significant changes require Change Advisory Board (CAB) review, and every deployment includes a documented rollback plan. **References:** SOC 2 CC8.1

Finding 10: [COMPLIANT] SOC 2: Monitoring and Incident Response (CC7) A centralized SIEM (Datadog) aggregates all system and security logs with 12-month retention and immutable storage protection. The Incident Response Plan (IRP) is tested semi-annually via table-top exercises, and a 72-hour breach notification window is committed. **References:** SOC 2 CC7.2, CC7.3

Finding 11: [COMPLIANT] SOC 2: Vendor Risk Management (CC9) Vendors accessing customer data must provide current SOC 2 Type II or ISO 27001 reports. Contracts include a strict 24-hour breach notification requirement and right-to-audit provisions. **References:** SOC 2 CC9.2

Finding 12: [COMPLIANT] SOC 2: Vulnerability and Training (CC1, CC7) Weekly automated Qualys scans and annual independent penetration tests are performed. Remediation is strictly tiered (Critical within 24 hours). Training includes quarterly phishing simulations and specialized secure coding for engineers. **References:** SOC 2 CC1.4, CC7.1